

CRM Sync — Security & Compliance Posture

The security and compliance posture: encrypted per-tenant credentials, scoped revocable tokens, **fail-closed** consent, and a PII-free audit trail by construction.

For: Compliance officers, security auditors, and risk assessment teams Date: 2026-06-15

THE PROBLEM

E-commerce businesses connect to 5-15 external platforms (Shopify, Google Analytics, Adobe, email providers, CRMs, CDPs). Each connection stores credentials, transfers customer data, and creates compliance obligations. The typical approach — storing API keys in environment variables, transferring data via CSV, managing consent in browser cookies — creates three compounding risks:

1. **Credential sprawl.** API keys and tokens scattered across config files, CI pipelines, environment variables, and team spreadsheets. Nobody knows where all the keys are stored, so nobody can confirm they're all rotated after an incident.
 2. **Consent without enforcement.** A consent banner sets a cookie. But the server that sends customer data to Salesforce, Klaviyo, or Google Analytics never checks that cookie. Consent is collected but not enforced.
 3. **No audit trail for data movement.** Customer data is exported as CSV, emailed between teams, uploaded to platforms. When a customer asks "where is my data?" or "delete my data," there is no log of which systems received it.
-

1. Credential Management

RISK	HOW CRM SYNC HANDLES IT
Credentials scattered across systems	All credentials stored in one encrypted location per tenant (Cloudflare KV)
Credentials visible in API responses	All secrets are automatically masked – only first 4 and last 4 characters shown
Credentials in code repositories	Credentials stored via encrypted secrets manager, never in source code
One compromised credential affects all clients	Each client (tenant) has its own isolated credentials – one breach cannot access another tenant's data
Credential rotation requires code changes	Updating a credential is a config change – same authenticated, logged process as any other update

2. Consent Enforcement

RISK	HOW CRM SYNC HANDLES IT
Consent collected but not enforced	Every data push to every platform checks the customer's consent state before sending
Consent stored only in browser cookies	Consent is persisted server-side in the database – survives cookie clearing, works for server-side operations
Consent changes don't propagate	When consent changes, all connected platforms are notified in the same request
No record of consent history	Every consent change is logged with timestamp, source, action, and which systems were notified
AI agents can't verify consent	Consent state is available via authenticated API – machine-readable, not browser-cookie-dependent

3. Audit Trail

RISK	HOW CRM SYNC HANDLES IT
No log of what data was sent where	Every outbound data push is logged per platform with status (success/failure) and timestamp
Customer asks "where is my data?"	UCP Dashboard shows which platforms have their data and when it was last synced
Customer requests deletion	GDPR handler anonymizes data across all connected systems and logs confirmation
Auditor asks for processing records	Consent log (append-only) + per-platform sync log = complete GDPR Art. 30 record
Config change with no record of who or when	Every configuration change requires authentication and can be logged with before/after comparison

4. Agent-Safe Credential Operations (Interactive Key Ceremony)

CRM Sync is built and operated with AI agents in the loop. That raises a question most stacks never answer: **what stops an automated agent from minting, reading, or leaking a production secret?** Our answer is structural, not a policy reminder — every privileged credential operation (mint, rotate, revoke, set) runs as a **two-role ceremony**.

RISK	HOW CRM SYNC HANDLES IT
An automation/AI agent could mint or read a production credential	Privileged credential commands are blocked for the agent by a permission classifier; only a named Security Human executes them interactively. The agent prepares the runbook and verifies the result — it never runs the mint
A secret ends up in a log, transcript, or model context	The new key's value is written straight to a <code>chmod 600</code> file or piped into the secrets manager — never printed. Read-back surfaces return a masked preview (<code>564bbe...9298</code>) or a <code>(set)</code> flag only
A botched rotation orphans the root key	Rotation is additive : a rotatable key lives alongside the root key, which never moves. A failed ceremony cannot lock anyone out; the root is the always-valid fallback
"Who rotated what, when?" with no provable trail	Each ceremony files an append-only audit record carrying SHA-256 fingerprints (never the secret): date, credential, action, executed-by, verified-by, old→new fingerprint, reason, consumers updated. The trail is itself safe to publish
Agent access outlives the engagement	The post-handoff access matrix covers humans and agents ; tier-boundary re-isolation re-mints every credential when crossing shared → private → enterprise

The full ceremony — flow diagram, trust-boundary model, and audit-record schema — is documented in `docs/KEY-MANAGEMENT-LIFECYCLE.md` §9 and specified normatively in `FUNCTIONAL-SPEC.md` §13 (FR-HANDOFF-02).

AUTHENTICATION LAYERS

CRM Sync uses four independent authentication mechanisms. Compromising one does not compromise the others:

LAYER	WHAT IT PROTECTS	HOW IT WORKS
Bearer Token	All admin and sync endpoints	API requests must include a secret key in the request header; per-tenant admin keys checked first, platform key as fallback
JWT Session	Customer-facing features (profile, consent, tags)	Signed token issued after login — expires automatically and is revoked server-side on logout (denylist with token-lifetime TTL), so a cached copy cannot outlive the session
HMAC Signature	All Shopify webhooks and GDPR handlers	Shopify signs each request — the Worker verifies the signature matches
Cloudflare Access	Browser access to admin pages	Email-based one-time password verification before any admin page loads

Route Coverage

All 67 API endpoints have been audited. Every endpoint that writes data or accesses admin functions requires authentication. 12 endpoints that were previously unprotected were fixed in the May 2026 security hardening. Per-tenant admin keys add granular access control — each tenant can have its own admin key, with the platform key as fallback.

Public endpoints (no auth required): health check, OAuth initiation pages, public embeds, read-only config (secrets masked).

Session Revocation & Self-Service Owner Keys (July 2026)

Two hardening rounds extended the authentication model beyond expiry-based sessions:

- **Server-side logout revocation.** Logout now denylists the session token at the server (hashed, TTL matched to the token's remaining lifetime). Previously a logged-out session remained technically valid until natural expiry; a token cached in browser storage or history could re-authenticate on a shared machine. Authenticated team surfaces also receive the session token at click time, hold it in memory only, and scrub it from URLs.
- **Self-service owner keys.** Each app owner holds a dedicated per-store credential they mint, rotate, and revoke themselves through an entitlement-gated wizard — ownership is granted by purchase, never self-assigned. The key value is shown exactly once at mint; rotation writes the replacement before revoking predecessors (no keyless failure mode); every event lands in a per-store, fingerprint-only, append-only audit ledger. The platform operates the key system but never holds the key value. Full treatment: `docs/KEY-MANAGEMENT-LIFECYCLE.md` §13.

The Partner Trust Problem

Every platform CRM Sync connects to is a trust boundary. A compromised credential or partner API could be used to access customer data. Here's how each partner's risk is contained:

PARTNER	WHAT COULD GO WRONG	HOW CRM SYNC CONTAINS IT
Shopify	Compromised admin token exposes customer data	Token stored per-tenant (not shared); auto-refreshed; scoped to minimum permissions
Webflow	Compromised CMS token allows data injection	Token scoped per site; data validated before writing
Google Analytics	API secret stolen allows fake event injection	Only category data sent (no personal information); synthetic user IDs prevent enumeration
Adobe AEP	OAuth compromise allows profile manipulation	Short-lived tokens; all personal data hashed before transmission
Email provider	API key compromise allows sending email as your brand	Only two email templates exist (welcome and password reset); tokens are single-use
Third-party code packages	Malicious code in dependency tree	Zero third-party packages in production — this entire risk category is eliminated

Disabling a Compromised Partner

If any partner is compromised, the response is:

1. Set that partner's toggle to "disabled" in config (one API call)
2. The credential is never read again
3. No code change, no deployment, no downtime
4. Takes less than 30 seconds

Data Subject Rights

RIGHT	HOW CRM SYNC SUPPORTS IT
Right of access (Art. 15)	UCP Dashboard shows customers their consent history, sync status, and which platforms have their data
Right to erasure (Art. 17)	Deletion handler anonymizes customer data across all connected systems and logs confirmation
Right to withdraw consent (Art. 7)	Consent toggle in dashboard → immediate propagation to all platforms
Records of processing (Art. 30)	Consent records (append-only) + per-platform sync logs = complete processing record
Data minimization (Art. 5)	Only consented data categories are pushed; personal information is hashed for analytics platforms

GDPR Webhooks

Three mandatory Shopify GDPR endpoints are implemented:

- 1. **Customer data request** — returns all stored data for a customer
- 2. **Customer deletion** — anonymizes all customer personal data
- 3. **Shop deletion** — deletes all data 48 hours after app uninstall

All three verify request authenticity via cryptographic signature before processing.

PRIVACY GUARANTEES

GUARANTEE	HOW IT'S ENFORCED
Consent before collection	Consent signals fire before any tracking; system defaults to "denied" if consent is unknown
Consent before sharing	Each platform has its own consent requirement; checked before every data push
Personal data never sent to analytics	Email, phone, and name are hashed (one-way) before sending to Google Analytics or Adobe
Tenant isolation	Each store's data and credentials are completely separate — one store cannot access another's data
Append-only audit logs	Consent changes and sync events cannot be modified or deleted — only new records are added

REMAINING HARDENING ITEMS

ITEM	PRIORITY	STATUS
Rate limiting on login and signup endpoints	Medium	Planned
Rate limiting on consent endpoint	Medium	Planned
Content Security Policy headers on embedded pages	Low	Planned
Security response headers on all API responses	Low	Planned

FOR AUDITORS: QUICK REFERENCE

Where are credentials? → Cloudflare KV, encrypted at rest, one key per tenant, masked in all API responses.

Where does customer data flow? → Only to platforms where (1) the platform is enabled in config AND (2) the customer has granted the required consent. Every transfer is logged.

How is consent tracked? → Server-side in Xano database, append-only log, timestamped, with source and affected systems recorded.

What happens during a breach? → Disable the affected platform (30 seconds). Credential is never read again. Per-tenant isolation means other tenants are unaffected.

What's the software supply chain risk? → Zero third-party packages in production. The processing engine uses only built-in platform capabilities.

Technical reference: [SECURITY-AUDIT.md](#) (route matrix, data pair contracts) Technical reference: [FEATURE-SPEC-UA-MIGRATION.md](#) (canonical specification)
